

COORDINATED VULNERABILITY DISCLOSURE REPORT

Email Authentication Infrastructure — capitecbank.co.za

Target: Capitec Bank (South Africa)

Domain: capitecbank.co.za

Disclosure ID: CAP-EMAIL-CVD-2026-06-04

Date: 2026-06-04

Recipient: cyberdefence@capitecbank.co.za

Method: Passive DNS Resolution Only — Non-Intrusive

Findings: 1 HIGH · 1 MEDIUM · 2 LOW · 1 INFORMATIONAL

Executive Summary

This disclosure reports five findings in the public email authentication posture of **capitecbank.co.za**, identified exclusively through passive DNS resolution of records published openly to the internet. No systems were accessed, no credentials were used, and no email was spoofed or sent.

The headline issue is a **latent Sender Policy Framework (SPF) failure condition**: your SPF record currently consumes **9 of the 10 DNS lookups permitted by RFC 7208**, leaving a single-lookup margin. Any one of your eight email vendors adding a nested `include` on their side — a change entirely outside Capitec's control — would silently push the record into a `PermError` state. When that happens, your strict `-all` hardfail becomes dead code and receivers may stop rejecting spoofed mail, opening a direct path to brand-impersonation phishing against your customers.

The remaining findings concern a missing subdomain DMARC policy (`sp=`), default-relaxed alignment, cross-border forensic-report delegation requiring a confirmed POPIA data-processing agreement, and a stale asset-inventory divergence. All findings carry **POPIA §19 'Security Safeguards'** relevance, with the forensic-report finding additionally implicating **§72 cross-border transfer** and **§107 penalty exposure** of up to **R10 million** and/or **10 years'** imprisonment.

Findings Summary

ID	Severity	CVSS v3.1	Title
CAP-SPF-01	HIGH	7.1	SPF Lookup Budget at 9/10 — Latent PermError / Hardfail-Bypass Risk
CAP-DMARC-02	MEDIUM	5.8	Missing <code>sp=</code> Subdomain Policy Tag
CAP-DMARC-05	LOW	4.3	Default Relaxed Identifier Alignment (<code>adkim/aspf</code> Unset)
CAP-RUF-04	LOW	3.1	Forensic Reports (<code>fo=1</code>) Delegated to External Processor Without Confirmed POPIA DPA
CAP-INTEL-06	INFORMATIONAL	N/A	Stale Asset Inventory — Dataset / Live DNS Divergence

Scope & Methodology

In scope: Publicly published DNS resource records for `capitecbank.co.za` governing email authentication — the SPF (TXT) record, the DMARC (TXT at `_dmarc.capitecbank.co.za`) record, and the recursive `include: chain` referenced by SPF.

- All evidence was obtained via standard recursive DNS TXT queries — identical to lookups any receiving MTA performs.
- No active exploitation was performed. No spoofed email was sent. No `-all` bypass was attempted. No Capitec system, portal, or mailbox was accessed.
- SPF lookup-budget arithmetic was computed statically against RFC 7208 §4.6.4 counting rules.
- Point-in-time validity: all records reflect DNS state as of 2026-06-04. DNS is mutable; re-validation is advised before acting.

Live Infrastructure Records — 2026-06-04

SPF Record (`capitecbank.co.za`):

```
v=spf1 include:za._netblocks.mimecast.com include:za.eversrv.com include:spf.protection.outlook.com include:_spf.salesforce.com include:cust-spf.exacttarget.com include:_spf-dc2.successfactors.com include:_spf.alchemer.com ip4:13.245.26.91 ip4:13.244.131.99 ip4:54.72.146.154 ip4:52.213.160.141
```

```
ip4:196.192.86.192 ip4:196.192.86.196 ip4:196.192.84.177 include:amazonses.com -all
```

DMARC Record (_dmarc.capitecbank.co.za):

```
v=DMARC1; p=reject; rua=mailto:9e6823b72e6b4b9390794c213676b299@dmarc-reports.cloudflare.net,mailto:0895b8e78e47683@rep.dmarcanalyzer.com; ruf=mailto:0895b8e78e47683@for.dmarcanalyzer.com; fo=1;
```

CAP-SPF-01

SPF Lookup Budget at 9/10 — Latent PermError / Hardfail-Bypass Risk

HIGH

CVSS 7.1

CVSS v3.1: 7.1 — CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:N/I:H/A:L

Tag / Value	Justification
AV — Network (N)	Weakness exercised remotely over SMTP/DNS; no local access required.
AC — High (H)	Exploitation depends on a vendor-side triggering condition, not solely attacker action.
PR — None (N)	No privileges on any Capitec system required.
UI — Required (R)	End-impact (phishing) requires a recipient to interact with the spoofed message.
S — Changed (C)	Vulnerable component: Capitec's SPF authority. Impacted: receiving MTAs and end-customers (trust boundary crossed).
C — None (N)	The flaw itself discloses no confidential data directly.
I — High (H)	Sender authenticity integrity destroyed — spoofed mail accepted as genuine Capitec mail.
A — Low (L)	Mail deliverability/reputation degradation is a realistic secondary impact.

CWE-693: Protection Mechanism Failure

The -all hardfail is the protection mechanism. When SPF evaluation returns PermError (RFC 7208 §4.6.4 exceeded), receivers do not reach the -all directive — the mechanism is bypassed not by defeating it, but by causing it to never execute.

Technical Description

RFC 7208 §4.6.4 imposes a hard ceiling of **10 DNS-querying mechanisms** (include, a, mx, ptr, exists, redirect) per SPF evaluation. Exceeding 10 forces a PermError. A PermError is **not** a fail — under RFC 7208 §8.6 many receivers treat it as none/neutral, meaning the -all hardfail is never honoured. Capitec's record currently sits at **9 of 10**. Critically, the Salesforce SPF uses an exists: macro consuming a second lookup beyond the include: that references it — a frequently-missed detail. The -all hardfail is therefore **conditional dead code**: any single vendor expanding their SPF by one lookup triggers PermError and silently neutralises the hardfail — requiring zero changes to Capitec's own DNS.

Evidence — SPF Lookup Chain Arithmetic

#	Mechanism	Cost	Running Total
1	include:za._netblocks.mimecast.com	1	1
2	include:za.eversrv.com	1	2
3	include:spf.protection.outlook.com	1	3
4	include:_spf.salesforce.com	1	4
5	■ exists: macro inside Salesforce SPF	1	5
6	include:cust-spf.exacttarget.com	1	6
7	include:_spf-dc2.successfactors.com	1	7
8	include:_spf.alchemer.com	1	8
9	include:amazonses.com	1	9
—	ip4: mechanisms (×7)	0 each	9
—	-all	0	9 / 10 ← LIMIT: 10

Threat Scenario — Vendor-Triggered Spoofing Window

1. A threat actor monitors Capitec's SPF chain passively (same DNS queries used in this report) and waits — or a vendor performs a routine SPF expansion pushing the count to 11.
2. SPF evaluation returns PermError. Receivers treating PermError as non-failing stop honouring -all.
3. Attacker sends mail with From: @capitecbank.co.za from unauthorized infrastructure.
4. With -all never reached, spoofed mail bypasses gateway rejection.
5. Customers receive fake fraud alerts and credential-harvesting links attributed to your domain — with degraded receiver-side rejection.

POPIA Impact

§19 (Security Safeguards): POPIA §19 obliges a responsible party to take 'appropriate, reasonable technical and organisational measures' to secure personal information. An SPF record that can silently fail-open via a foreseeable vendor change is not a reasonable measure against a known RFC limit. A resulting spoofing window enabling customer phishing directly degrades that safeguard. **Penalty exposure under POPIA §107: up to R10 million and/or 10 years' imprisonment for the responsible party.**

Recommended Remediation

- (Best) Adopt SPF flattening with monitored automation — resolve the eight includes to IP literals, holding the live lookup count at ≤4 with automated vendor-IP sync.
- (Strong) Audit and prune unused include: senders. Candidates: alchemer (survey), successfactors (HR), cust-spf.exacttarget.com (legacy SFMC). Confirm with mail-flow telemetry before removing.
- (Mandatory baseline) Deploy SPF lookup-count monitoring alerting when count reaches 8, giving lead time before PermError.
- Do NOT weaken -all to ~all as a workaround — that trades a latent failure for a permanent one.

References: RFC 7208 §4.6.4, §8.6, §5.1; CWE-693; POPIA §19, §107.

CAP-DMARC-02

Missing sp= Subdomain Policy Tag

MEDIUM

CVSS 5.8

CVSS v3.1: 5.8 — CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:N

Tag / Value	Justification
AV — Network (N)	Subdomain spoofing is delivered remotely over SMTP.
AC — High (H)	Requires attacker to identify unprovisioned subdomain and craft aligned mail.
PR — None (N)	No Capitec privileges needed.
UI — Required (R)	Recipient must open/act on the spoofed subdomain mail.
S — Changed (C)	Policy authority is Capitec's; impact lands on receivers and customers.
C — Low (L)	Limited confidentiality impact via harvested customer responses.
I — Low (L)	Partial sender-authenticity erosion at subdomain scope.
A — None (N)	No availability impact.

CWE-285: Improper Authorization / CWE-16: Configuration

DMARC's sp= tag is the authorization control governing whether organizational policy extends to subdomains. Its absence means subdomain authorization relies on implicit inheritance rather than explicit assertion — a configuration omission (CWE-16) producing an authorization gap (CWE-285).

Evidence

Live DMARC record (2026-06-04) tags present: v, p=reject, rua, ruf, fo. **Tag absent: sp=.** Organizational policy is reject but no explicit subdomain policy is asserted. Per RFC 7489, subdomains inherit p= by default — but inheritance is implicit, not asserted, and is not guaranteed across all receivers.

Threat Scenario — Lookalike Subdomain Phishing

- Attacker enumerates plausible unprovisioned subdomains: notifications.capitecbank.co.za, secure.capitecbank.co.za, alerts.capitecbank.co.za.
- Mail from such a subdomain may not be rejected at full reject strength if receiver implicit-inheritance behaviour diverges from ideal.
- Customers trust the subdomain label and act on the fraudulent message.

POPIA Impact — §19 (Security Safeguards)

Leaving subdomain authentication to implicit inheritance is a gap in the 'appropriate, reasonable technical measures' required by §19 when the explicit control (sp=reject) is trivially available. **Penalty exposure under POPIA §107: up to R10 million and/or 10 years' imprisonment for the responsible party.**

Recommended Remediation

Republish _dmarc.capitecbank.co.za as:

```
v=DMARC1; p=reject; sp=reject; adkim=s; aspf=s;
rua=mailto:9e6823b72e6b4b9390794c213676b299@dmARC-reports.cloudflare.net,
mailto:0895b8e78e47683@rep.dmarcanalyzer.com; ruf=mailto:0895b8e78e47683@for.dmarcanalyzer.com;
fo=1;
```

References: RFC 7489 §6.3, §6.6.3; CWE-285, CWE-16; POPIA §19, §107.

CAP-DMARC-05

Default Relaxed Identifier Alignment (adkim/aspf Unset)

LOW
CVSS 4.3

CVSS v3.1: 4.3 — CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N

Tag / Value	Justification
AV — Network (N)	Exploited remotely via SMTP using a relaxed-aligned sender.
AC — High (H)	Requires attacker to control a domain satisfying relaxed (org-domain) alignment.
PR — None (N)	No privileges required.
UI — Required (R)	Recipient interaction needed for phishing impact.
S — Unchanged (U)	Alignment weakness operates within DMARC evaluation of the same organizational domain.
C — Low (L)	Limited confidentiality impact.
I — Low (L)	Limited sender-authenticity integrity impact.
A — None (N)	No availability impact.

CWE-287: Improper Authentication / CWE-1390

Relaxed alignment authenticates the sender at organizational-domain level, accepting a broader set of identifiers than the available strict mode requires — an authentication policy weaker than necessary.

Evidence

Live DMARC record (2026-06-04) contains neither adkim nor aspf. Per RFC 7489 §6.3, both default to r (relaxed). No explicit alignment tightening is asserted.

POPIA Impact — §19 (Security Safeguards)

Defaulting to relaxed alignment where strict is trivially available is a sub-optimal 'reasonable technical measure' under §19, compounded by CAP-DMARC-02. **Penalty exposure under POPIA §107: up to R10 million and/or 10 years'**

imprisonment for the responsible party.

Recommended Remediation

Add `adkim=s; aspf=s;` to the DMARC record (consolidated in CAP-DMARC-02 above). Pre-flight: validate via rua aggregate reports over a 2–4 week window to confirm no legitimate sender relies on relaxed alignment before enforcing.

References: RFC 7489 §3.1, §6.3; CWE-287, CWE-1390; POPIA §19, §107.

CAP-RUF-04

Forensic Reports (fo=1) Delegated to External Processor Without Confirmed POPIA DPA

LOW

CVSS 3.1

CVSS v3.1: 3.1 — CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Tag / Value	Justification
AV — Network (N)	Forensic reports traverse the network to an external third-party mailbox.
AC — High (H)	Exposure depends on report-triggering conditions and third-party handling.
PR — None (N)	No privileges required.
UI — None (N)	No victim interaction required; data flow is automatic.
S — Unchanged (U)	Impact stays within the data-handling component.
C — Low (L)	Message header fragments may contain limited personal information.
I — None (N)	No integrity impact.
A — None (N)	No availability impact.

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

fo=1 generates DMARC failure (forensic) reports embedding fragments of failing message headers — potentially including subject lines, sender/recipient addresses, and routing metadata — shipped automatically to an external processor without confirmed POPIA authorization.

Evidence

```
ruf=mailto:0895b8e78e47683@for.dmarcanalyzer.com; fo=1;
```

fo=1 requests forensic reports on any SPF or DKIM failure. Reports route to a third-party, likely foreign-domiciled processor. No DPA or §72 transfer safeguard is verifiable from public data.

POPIA Impact — §19 (Security Safeguards) AND §72 (Transfers Outside the Republic)

§19: Personal information in forensic reports must be processed under appropriate measures including a written operator agreement per §20–§21. **§72:** Transfer to a foreign-country processor is lawful only under specific conditions (comparable law/agreement, data-subject consent, or necessity). Routing forensic header data without a confirmed §72 basis is a potential unlawful cross-border transfer. **Penalty exposure under POPIA §107: up to R10 million and/or 10 years' imprisonment for the responsible party.**

Recommended Remediation

- (Best) Confirm or execute a POPIA-compliant DPA with DMARC Analyzer covering operator obligations (§20–§21) and a lawful §72 cross-border basis.
- (Alternative) Remove `ruf=` and `fo=` entirely if forensic granularity is not operationally required — eliminates the personal-information transfer vector outright.
- Aggregate rua reports (no message-content fragments) remain available regardless of whether `ruf=`/`fo=` are removed.

References: RFC 7489 §6.3, RFC 6591; CWE-200; POPIA §19, §20, §21, §72, §107.

CAP-INTEL-06

State Asset Inventory — Dataset / Live DNS Divergence

INFORMATIONAL

CVSS N/A

CWE-1059: Insufficient Technical Documentation (Operational Hygiene)

Security decisions made on an inaccurate inventory are decisions made blind. The vulnerability is not in a live record but in the accuracy of the asset dataset.

Evidence — Dataset vs. Live DNS

Item	In Stale Dataset	In Live DNS	Risk Note
include: Intercom	Yes	No	Phantom sender — not authorized live
include: Mailchimp (mcsv.net)	Yes	No	Phantom sender — not authorized live
rua to 2u.com	Yes	No	Stale reporting destination
ip4:164.151.128.0/19	Yes	No	8,192 addresses — authorized only in stale data

The /19 is the most significant divergence: 164.151.128.0/19 spans **8,192 IP addresses**. If this range informed any past security or allow-list decision, that decision rested on incorrect data.

POPIA Impact — §19 (Security Safeguards) — Indirect

§19 requires safeguards based on an accurate understanding of the processing environment. A stale inventory produces blind spots undermining the reasonableness of those safeguards.

Recommended Remediation

- Treat live DNS as the single source of truth for email-sender authorization; deprecate the stale dataset immediately.
- Verify nothing currently trusts 164.151.128.0/19 or phantom Intercom/Mailchimp entries in any allow-list or risk assessment.
- Institute automated monthly DNS-vs-inventory reconciliation.

References: CWE-1059; RFC 7208; POPIA §19, §107.

Priority Remediation Roadmap

#	Tier	Finding ID	Action
1	IMMEDIATE 0–7 days	CAP-SPF-01	Deploy SPF lookup-count monitoring/alerting at the 8-lookup threshold today. Begin scoping SPF flattening.
2	IMMEDIATE 0–7 days	CAP-INTEL-06	Confirm no live allow-list trusts 164.151.128.0/19 or phantom Intercom/Mailchimp entries.
3	IMMEDIATE 0–7 days	CAP-RUF-04	Confirm POPIA DPA exists with DMARC Analyzer, or remove ruf=/fo= pending confirmation.
4	30 DAYS	CAP-SPF-01	Complete SPF flattening or vendor pruning to bring evaluated lookup count to ≤ 4 .
5	30 DAYS	CAP-DMARC-02	Publish explicit sp=reject.
6	30 DAYS	CAP-RUF-04	Finalize POPIA §72 cross-border basis and §20–§21 operator agreement.
7	90 DAYS	CAP-DMARC-05	After 2–4 week rua monitoring window confirming exact alignment for all legitimate senders, enforce adkim=s; aspf=s.
8	90 DAYS	CAP-INTEL-06	Stand up automated monthly DNS-vs-inventory reconciliation.
9	90 DAYS	ALL	Full re-validation pass — confirm closure of all five findings.

Responsible Disclosure Statement

This report is provided in good faith under coordinated vulnerability disclosure principles. The researcher confirms the following without reservation:

- **Passive methods only.** Every finding was derived solely from publicly published DNS records resolved via standard recursive TXT queries — identical to the lookups any mail receiver performs.
- **No exploitation.** No spoofed email was sent, no -all bypass was attempted against a live receiver, no subdomain was registered or taken over, and no SPF PermError was induced.
- **No data accessed or retained.** No personal information of Capitec, its employees, or its customers was accessed, collected, or stored.
- **No third-party disclosure.** This report is provided exclusively to Capitec Bank's Cyber Defence team. The researcher will not publish, share, or disclose these findings to any third party and supports a reasonable remediation window.
- **Intent.** The sole purpose of this disclosure is to enable Capitec to strengthen its email authentication posture and protect its customers before these latent conditions can be abused.
- No compensation is requested. The researcher is available to clarify any finding or assist with validation at no cost.

Researcher Contact

Field	Detail
Researcher	Independent Security Researcher (Good-Faith CVD)
Email	lawrencetshabalala253@gmail.com
Disclosure ID	CAP-EMAIL-CVD-2026-06-04
Date Submitted	2026-06-04
PGP	Available on request for encrypted follow-up

This document is classified CONFIDENTIAL and intended solely for the Capitec Bank Cyber Defence team. All findings reflect DNS state as of 2026-06-04 and should be re-validated prior to remediation, as DNS records are mutable.

END OF DISCLOSURE — 1 HIGH · 1 MEDIUM · 2 LOW · 1 INFORMATIONAL